GUEST PRESENTATION

MIRQAB

AI-Powered Security Operations Platform for SMBs

Bdoor Fahed Alosaimi

Nouf Saleh Altalhi

Alaa Rafa Al Saad

OPENING

A watchtower for every small business

MIRQAB gives a small or medium-sized business the core workflow of a Security Operations Center — without a SOC-sized team.

1

See

Turn raw security events into explainable incidents with evidence and MITRE ATT&CK context.

2

Decide

Every HIGH/CRITICAL incident gets a 5-minute response clock and guided investigation.

3

Act

Contain an endpoint only through an authorized, agent-confirmed, audited action.

THE PROBLEM

Same attacks as enterprises. A fraction of the defenders.

What SMBs face

- Phishing and malicious attachments
- Credential brute-force
- Ransomware and data encryption
- Command-and-control beacons

What they lack

- Context — tools emit raw alerts, not incidents
- Ownership — nobody on the clock for a critical alert
- Safe automation — "block everything" can hurt the business
- Privacy — internal logs can't go to external AI

WHY SMBS NEED SOC CAPABILITIES

Detection alone is not security

A SOC is the loop that connects an alert to a decision and an action. SMBs usually have tools that detect, but no loop.

Triage

Which of today's alerts actually matter?

Investigate

What happened, where, and have we seen it before?

Respond

Who acts, how fast, and with what authority?

Prove

What was done — and can we show it afterwards?

MIRQAB OVERVIEW

Three applications, one backend

SOC Dashboard

React web app for Admins, Security Analysts and IT Technicians: overview, incidents, live network map, tickets, policies, reports, audit logs, user management. VERIFIED

Backend API

NestJS + PostgreSQL + Prisma + Redis + Socket.IO: ingestion, detection, correlation, response window, endpoint control, reports. VERIFIED
421 tests passing

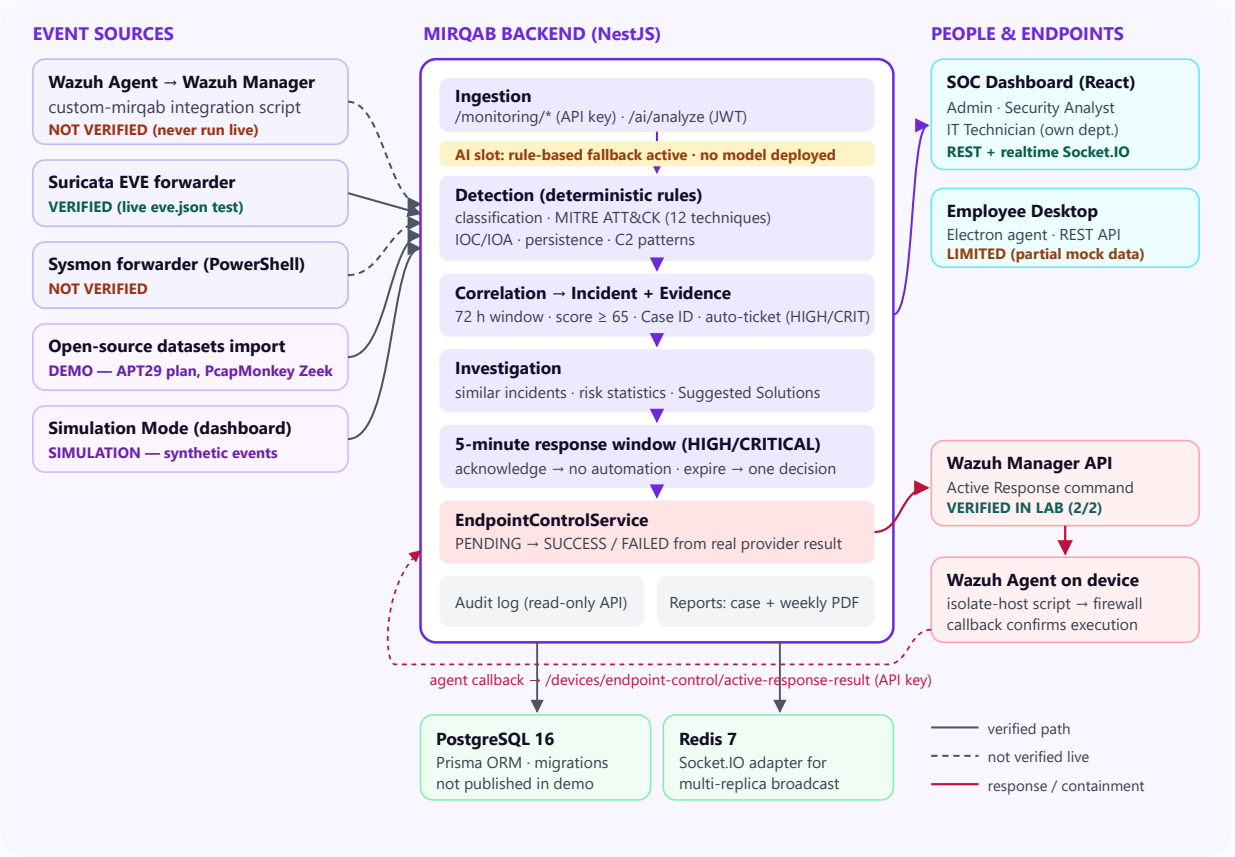
Employee Desktop

Electron agent: device health, security score, device info, recommended fixes. LIMITED parts use clearly-marked mock data

Status on 27 Sep 2026: working prototype running locally in Docker — NOT DEPLOYED to production.

ARCHITECTURE

The actual data flow



Dashed = implemented but not verified live. MIRQAB does not read from the Wazuh Indexer.

SOC WORKFLOW

From event to evidence-backed decision

1. **Ingest**
   Wazuh, Suricata, Sysmon forwarders — plus public datasets and Simulation Mode for demos.

2. **Detect**
   Rule-based severity, MITRE technique, IOC/IOA, persistence and C2 patterns.

3. **Correlate**
   Merge related events into one case (72 h, score ≥ 65) with a Case ID.

4. **Alert**
   HIGH/CRITICAL: auto-ticket, notification, 5-minute response window.

5. **Investigate & respond**
   Evidence, similar incidents, Suggested Solutions, confirmed actions.

6. **Record**
   Timeline, audit log, case report and weekly report.

INCIDENT DETECTION

Deterministic, explainable detection

What runs on every event

- **Classification** — severity from rules
- **MITRE ATT&CK** — 12 curated techniques
- **IOC** — IPs, hashes, domains, URLs, emails
- **IOA** — credential dumping, lateral movement, process injection, obfuscation, defense evasion
- **Correlation** into an existing open case or a new one

Honest by design

No match → no indicator, and unmatched events stay **UNCLASSIFIED** rather than guessed.

In the evaluator demo, 11 of the 27 incidents created from public datasets stay UNCLASSIFIED; the dataset notes report all 6 network-flow events landing UNCLASSIFIED / LOW.

VERIFIED LIMITED coverage

5-MINUTE RESPONSE WORKFLOW

Every critical incident gets a clock

T0
Detected
HIGH/CRITICAL incident created. Deadline = T0 + 5 min.

T0
Notified
"Response required" to the SOC users who can see it.

< 5 MIN
Acknowledged
Analyst acknowledges → no automated containment, ever.

5 MIN
Expired
One once-only decision under a database lock.

AFTER
Recorded
Outcome, notification and audit entry; late responses are logged.

MEDIUM and LOW incidents never trigger automated containment — they always wait for an analyst. Logic VERIFIED by unit tests.

NOTIFICATION

Who is told — and who is not

Implemented

- Real-time in-app notifications over Socket.IO
- "Response required" for new HIGH/CRITICAL incidents
- "Containment result" when a window expires
- Recipients = exactly the SOC users allowed to see the incident (Admin, Security Analyst, IT Technician of that department)

VERIFIED

Not yet: the employee

The backend has no per-employee ownership model for incidents, so the affected employee is **not** notified individually.

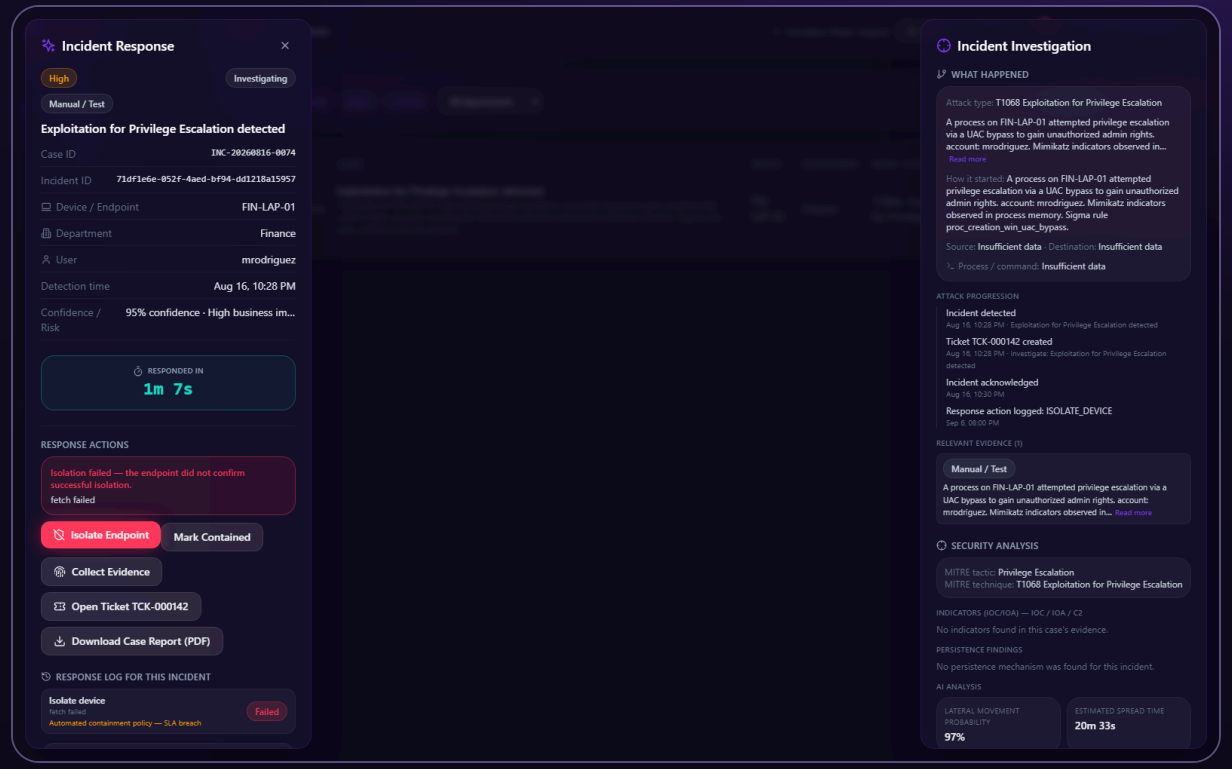
The Employee Desktop app shows device health and recommended fixes; some screens use clearly-marked mock data.

LIMITED

ACKNOWLEDGEMENT

"Acknowledge & Investigate"

- Records who responded and when
- Idempotent — a second click creates no duplicate record
- Before the deadline: automated containment is cancelled for good
- After the deadline: logged as a late response — it never silently undoes an isolation
- Any status change also counts as a response



Real screenshot (22 Sep 2026): "Responded in 1m 7s" — development test incident.

AUTOMATED CONTAINMENT ELIGIBILITY

Automation only when every condition holds

Isolation is requested only if…

- Severity is HIGH or CRITICAL
- Nobody responded within 5 minutes
- The incident is **not** simulated
- The "5-Minute Response Window" policy is enabled
- An endpoint-control provider is configured

…and then

- A PENDING action is saved first
- The real provider is called
- The same record becomes SUCCESS or FAILED from the real result
- No AI is consulted — the decision is rule-based

In development, attempts were recorded **FAILED** (no reachable endpoint). A successful automated isolation on a live agent is not yet shown. LIMITED

WAZUH ACTIVE RESPONSE

Containment we can prove

1. **Authorize**
   Role and department checked; device resolved on the server from the incident.

2. **Confirm**
   Analyst confirms: "only this endpoint is affected".

3. **Dispatch**
   MIRQAB → Wazuh Manager API → Active Response.

4. **Verify**
   Agent script applies firewall isolation and calls back; only then SUCCESS.

Evidence

VERIFIED IN LAB 2/2 end-to-end isolations through MIRQAB on a containerized Linux safe-test agent (11–15 s).

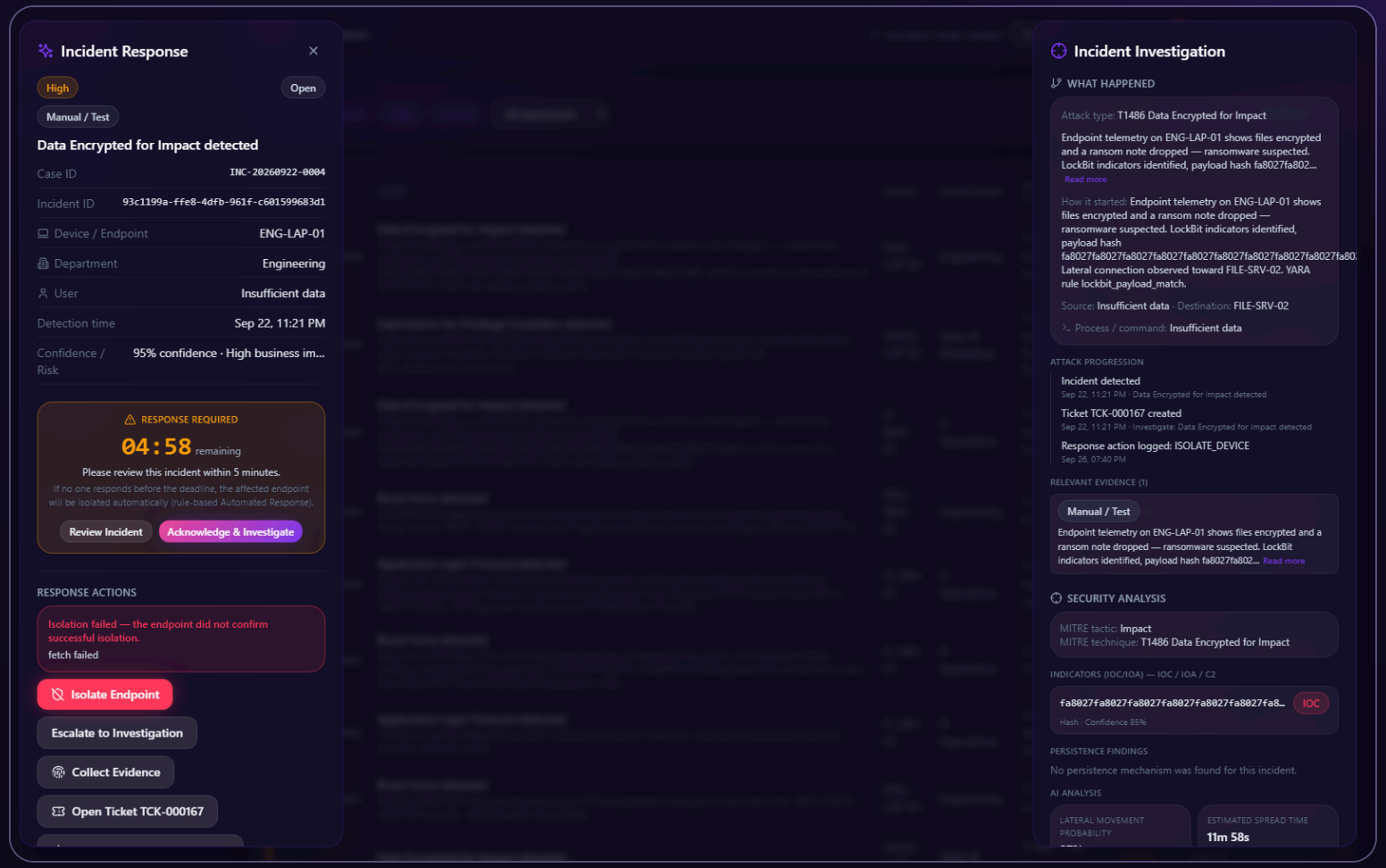
NOT VERIFIED Windows script · physical devices

NOT IMPLEMENTED release isolation from MIRQAB

BLOCKED Wazuh GA 4.14.7 (lab ran a release candidate)

INVESTIGATION

Two windows: respond and understand



Real screenshot (26 Sep 2026) — development test incident ("Manual / Test"). The red notice is a genuine FAILED isolation: the virtual device has no real endpoint behind it.

MITRE ATT&CK

12 curated techniques, mapped deterministically

ID	Technique	Tactic
T1566	Phishing	Initial Access
T1110	Brute Force	Credential Access
T1204	User Execution	Execution
T1059	Command & Scripting Interpreter	Execution
T1046	Network Service Discovery	Discovery
T1068	Exploitation for Priv. Escalation	Privilege Escalation
T1053	Scheduled Task/Job	Persistence
T1078	Valid Accounts	Persistence
T1071	Application Layer Protocol	Command and Control
T1105	Ingress Tool Transfer	Command and Control
T1567	Exfiltration Over Web Service	Exfiltration
T1486	Data Encrypted for Impact	Impact

Why curated?

Every mapping must be explainable and testable. If an AI provider is ever enabled, its output is validated against this reference to reject invented technique IDs.

Unmatched events stay **UNCLASSIFIED**.

VERIFIED LIMITED

IOC & EVIDENCE

Indicators extracted — never invented

IOC

IP addresses, file hashes, domains, URLs, email addresses — each with a confidence value.

IOA

Behaviour patterns: credential dumping, lateral movement, process injection, obfuscated execution, defense evasion.

Evidence

Every contributing event kept with its raw excerpt, source label (Live Agent · Dataset · Simulation · Manual/Test) and correlation score.

Persistence (scheduled tasks, services, run keys…) and C2 beacon patterns are detected and mapped to MITRE as well.

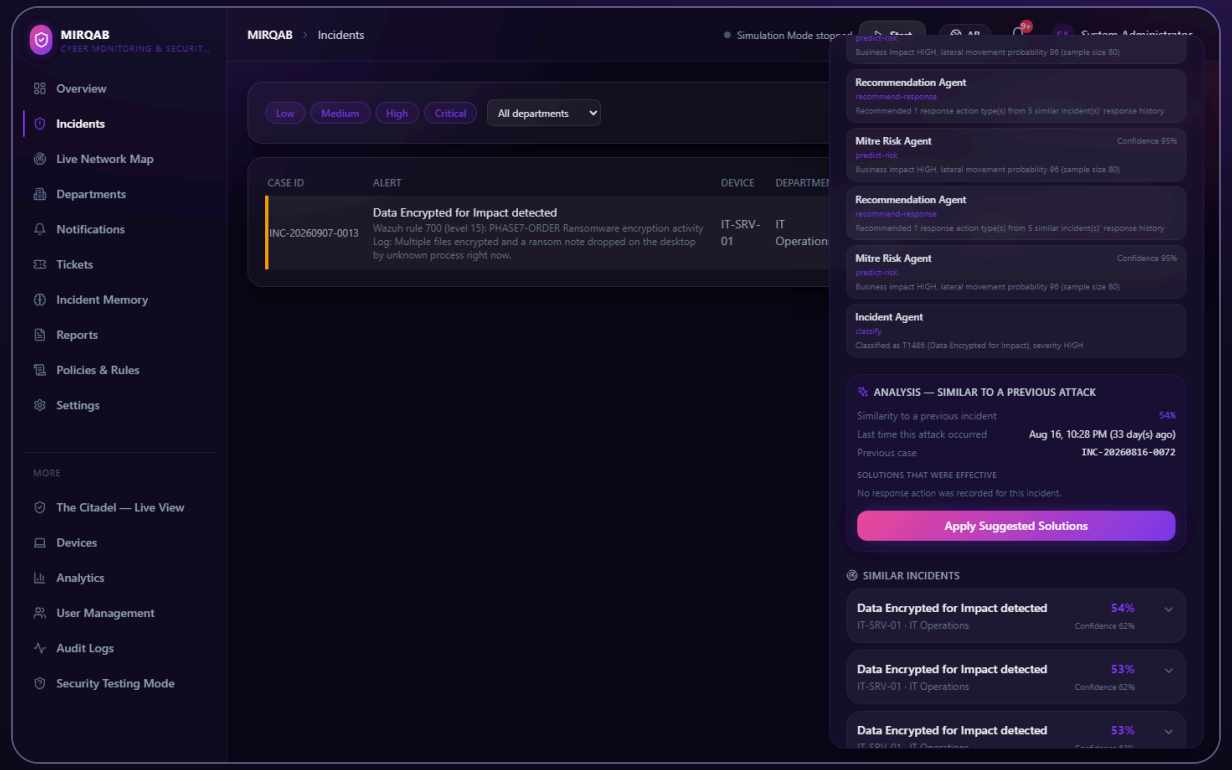
VERIFIED

SUGGESTED SOLUTIONS

Learn from what worked before

- Similar past incidents found by native vector similarity (department-scoped)
- Fixes from a per-technique catalog + actions that were effective on similar cases
- "Apply Suggested Solutions" creates actions — high-impact ones need analyst approval
- AI "agents" shown in the panel are named wrappers around deterministic services; none can execute a response

VERIFIED



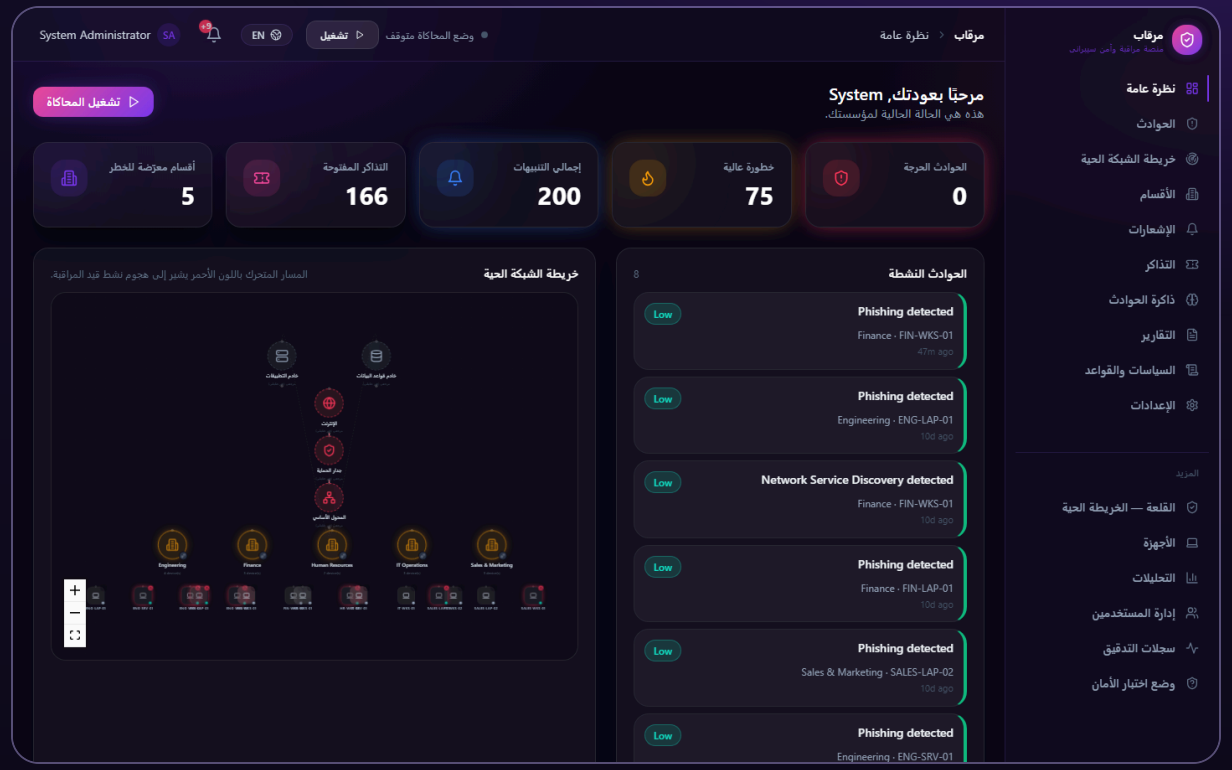
Real screenshot (19 Sep 2026) — 54% similarity to a case from 33 days earlier.

DIGITAL TWIN

The organization as a live map

- Internet → firewall → core switch → servers → departments → devices
- Active attacks highlighted; click a device to open its incident
- "The Citadel — Live View" wallboard
- Attack Path view of the public APT29 emulation plan **DEMO**
- Built from MIRQAB's own device and incident records — not a network scanner

VERIFIED



Real screenshot (20 Sep 2026), Arabic interface — figures are development data.

REPORTS

Proof, on demand and every week

1

Case report (PDF)

11 sections per incident: summary, evidence, timeline, IOC, IOA, persistence, C2, AI analysis, response actions, recommendations, audit trail. Access-controlled like the incident.

VERIFIED

7

Weekly SOC report (PDF)

Generated every Monday 05:00 UTC for the just-completed week, per organization — or on demand from the Reports page.

VERIFIED

SECURITY CONTROLS

Secured and tested in 18 phases

Identity

- JWT pinned to HS256
- Rotating refresh tokens + reuse detection
- bcrypt · rate-limited login (5/min)

Access

- 4 roles, department scoping
- Organization isolation
- Object-level guards (IDOR/BOLA)

Platform

- Strict input validation
- Authenticated, room-scoped Socket.IO
- Read-only audit log · TLS · non-root container

38 test suites / 421 backend tests passing on 27 Sep 2026. Phases 4 (Wazuh version) BLOCKED and 8 (self-hosted AI) NOT VERIFIED.

DEMO FLOW

What we will show

1. Login
2. Dashboard
3. Incident
4. Investigation
5. Evidence
6. MITRE
7. Suggested Solutions
8. Response timer
9. Network map
10. Isolation workflow
11. Notifications
12. Reports

Demo data: public OTRF Security-Datasets APT29 plan and PcapMonkey Zeek events. The demo cannot isolate real endpoints and does not use external AI. DEMO

LIMITATIONS

What we are honest about

- NOT DEPLOYED Runs locally in Docker; self-signed TLS
- NOT VERIFIED Self-hosted AI — no model deployed; all analysis is rule-based
- LAB ONLY Isolation proven on a containerized agent, not physical devices
- LIMITED Automated containment not yet shown succeeding live
- BLOCKED Wazuh GA 4.14.7 image unavailable when checked
- NOT VERIFIED Wazuh Manager forwarding script; Sysmon forwarder
- LIMITED 12 MITRE techniques · partial Arabic labels · SOC-only notifications
- NOT VERIFIED Load testing · demo on a separate clean machine

FUTURE ROADMAP

Next steps PLANNED

Private AI

Deploy and evaluate a self-hosted model on suitable hardware inside the customer network.

Real endpoints

Validate isolation on physical Windows and Linux devices; add "release isolation".

Production

Real domain and CA-issued TLS, automated backups, disaster-recovery procedure, load testing.

Wazuh

Move to a GA release; run the Manager integration end-to-end.

Coverage

More MITRE techniques and detection rules.

People

Full Arabic translation; employee-level notifications.

TEAM

Thank you

MIRQAB — AI-Powered Security Operations Platform for SMBs

Bdoor Fahed Alosaimi

Nouf Saleh Altalhi

Alaa Rafa Al Saad

Questions welcome — see also the Judges Q&A and the Security documentation in this package.